

arxdsilva

@arxdsilva

Myth: updating to the newest dependency version right away is safest.

Malicious versions usually get caught within hours or days, the Rust team writes.

Rust 1.100 now lets Cargo wait out that window.





arxdsilva

@arxdsilva

My rule: let new versions age a few days before they reach your build.

Fair default or false comfort? Pick a side, then save this.

- Cargo skips versions newer than your min-publish-age and lists what it held back.
- Need a fix today? One env var overrides it for a single update.
- Counterpoint: cargo install ignores it, and the Rust team calls it no complete defense.